

מסמך אפיון בדיקות – HavuGym Crew

מכסה את סעיפים 6 ו-7 בבריף: מה צריך להיבדק, ולמה, ואיפה זה ממומש.

1. מה נחשב "המוצר עובד"

לפני רשימת הבדיקות צריך להגדיר את הטענה. המוצר עובד אם **כל חמש הטענות הבאות נכונות בו-זמנית**:

#	טענה	אם היא נשברת
1	חבר רואה את החבורה שלו, ורק אותה	דליפת מידע בין קבוצות – כשל חמור
2	ציון האימון נקבע בשרת ומשקף את מה שהורם	הדירוג חסר משמעות, המוצר מת
3	קריאטין נוצר ונגרע רק דרך מסלול אחד, ופעם אחת	כלכלה שבורה; אפשר לייצר כסף
4	שבוע נסגר בדיוק פעם אחת, והקופה משולמת במלואה	תשלום כפול או חלקי
5	קלט לא תקין נדחה עם הודעה מובנת	חוויה גרועה או שורה מושחתת

כל קבוצת בדיקות למטה קשורה לטענה מהטבלה הזו. בדיקה שלא משרתת אחת מהן לא נכתבה.

2. אסטרטגיה – שלוש רמות

רמה	כלי	מה היא מוכיחה	כמות
Unit	Vitest	לוגיקה עסקית טהורה, כולל מקרי קצה	110
Integration	Vitest + מסד אמיתי	ש-Postgres מסרב, לא שאנחנו חושבים שהוא מסרב	46
End-to-end	Playwright	שהמסע השלם מחזיק בפריסה החיה	8
		סה"כ	164

2.1 למה בדיקות האינטגרציה לא ממוקדות

זו ההחלטה המרכזית במסמך. אפשר היה לדמות (mock) את ה-Supabase client ולבדוק ש"המשתמש לא מקבל נתונים". זה היה מוכיח **שה-mock שלנו מסרב** – כלומר, שכתבנו נכון את ההנחה שלנו. הטענה שצריך להוכיח היא ש-Postgres מסרב, על סמך policies אמיתיות, grants אמיתיים ו-JWT אמיתי. לכן הבדיקות האלה יוצרות משתמשים אמיתיים, מתחברות באמת, ותוקפות באמת.

2.2 למה הן מופרדות

`npm test` מריץ רק `unit` – מהיר, `offline`, דטרמיניסטי. `npm run test:integration` דורש הרשאות ורשת. הפרדה זו מונעת מהחבילה המהירה להפוך לאיטית ולשבירית.

3. בדיקות לפיצ'רים המרכזיים

3.1 ציון האימון – (20) tests/scoring.test.ts

מה נבדק	למה זה חשוב
עבודה = חזרות × משקל	הבסיס
תרגיל משקל-גוף מקבל proxy של 30 ק"ג	מתח אינו אפס עבודה. אחרת יום מתחים מקבל 0
משקל חיצוני נוסף ל-proxy	מתח עם חגורה שווה יותר ממתח
סט בעומס 0 בצידוד רגיל = 0 עבודה	קלט אמיתי, לא באג
חציון בשיטת percentile_cont	$[10, 20, 30, 40] = 25$. אי-התאמה כאן שוברת את הזהות מול SQL
אימון בדיוק על הבייסליין → Load 25, Density 15	הגדרת "יום רגיל"
פי עשרה מהרגיל לא נותן פי עשרה ציון	תקרת היחס
אימון ראשון – בייסליין ניטרלי	לא מחמיא ולא מעניש
Coverage חסום ב-20	מונע "פיזור" מלאכותי
הציון תמיד 0–100	אינווריאנט
רק 8 האימונים האחרונים נספרים	outlier ישן לא מזיז את הבייסליין
דטרמיניזם	אותו קלט → אותו ציון

3.2 סגירת תחרות – (13) tests/competition.test.ts

מה נבדק	למה
פודיום נקי → 350 / 100 / 50	70/20/10 מ-500
סכום הזכיות = הקופה בדיוק – נבדק על 1,333,719,999,000	largest remainder. עיגול נאיבי ממציא או מאבד קריאטין
דירוג תחרותי: תיקו ב-1 → הבא הוא 3	הסמנטיקה המקובלת
תיקו מאחד נתחים ומחלק (225/225/50)	אחרת הראשון אלפביתית זוכה ב-70%
משתתף יחיד מקבל את כל הקופה	לא משאירים 30% תלויים
שני משתתפים – חלוקה מחדש, סכום = קופה	
מי שלא התאמן מדורג אך לא מקבל	
אף אחד לא התאמן → אפס תשלומים	
חבורה ריקה → מערך ריק	
קופה 0 → אפס תשלומים	
אי-תלות בסדר הקלט	דטרמיניזם
שובר-שוויון יציב	לא סדר מערך
אין תשלום שלילי, גם בקופה של 3 לארבעה	

3.3 גבולות שבוע – (8) tests/time.test.ts

הבדיקה החשובה ביותר בקובץ:

```
// 22:00Z בשבת = ראשון בירושלים – תחילת שבוע חדש
expect(weekStartOf(new Date('2026-09-05T22:00:00Z'))).toBe('2026-09-06');

// 20:00Z בשבת = שבת בירושלים – עדיין השבוע הישן
expect(weekStartOf(new Date('2026-09-05T20:00:00Z'))).toBe('2026-08-30');
```

שתי הבדיקות האלה נמצאות במרחק שעתיים זו מזו ונופלות בשני שבועות שונים. בלעדיהן, אימון בליל שבת היה משולם לשבוע שכבר נסגר. זה בדיוק הבאג שקרה במערכת הפרודקשן.

3.4 אתגר והמלצה – 16 בדיקות

רוטציה דטרמיניסטית לפי שבוע; ספירת שרירים **ייחודיים**; המלצה מעדיפה שריר שמעולם לא אומן; קצב נמדד מול הימים שחלפו – אותו מספר ביום ראשון "בקצב" וביום שישי "מפגר".

3.5 הגעות – (15) tests/arrival.test.ts

מה נבדק	למה זה חשוב
הצופה אינו נספר בעדר	העדר הוא אנשים אחרים. ספירת עצמך הופכת את האות לחסר משמעות
הגעה שחלונה נסגר יורדת מהרשימה	אות שקרי גרוע מאין אות
עוצמה מסלימה: $0 \rightarrow 1 \rightarrow 2 \rightarrow +3$	המספר הוא המנגנון
שמות עד שניים, ספירה מעליהם	מעבר לכך הספירה היא המסר, לא מפקד השמות
מי שכבר במכון מוצג לפני מי שבדרך	עובדה חזקה מכוונה, גם אם הוכרזה מאוחר יותר
ניסוח לחבורה מעורבת	"Dana במכון, Itay בדרך"
מכון ריק מזמין את הראשון	מצב אמיתי עם קריאה לפעולה משלו
חבר יחיד בחוץ נאמר לו שהנראות עצמה היא המנגנון	
דטרמיניזם	אותו קלט $\rightarrow$ אותו ניסוח

4. בדיקות לקלטים לא תקינים – (20) `tests/validation.test.ts`

קלט	התוצאה הנדרשת
אימייל עם רווחים ואותיות גדולות	מנורמל
סיסמה בת 7 תווים	נדחית
סיסמה מעל 72 בתים	נדחית – bcrypt חותך בשקט; עדיף לסרב
שם תצוגה בן תו אחד	נדחה
קוד הזמנה באורך 5 או 7	נדחה
קוד עם מקף	נדחה
משקל 0 בתרגיל משקל-גוף	מתקבל – קלט חוקי
משקל שלילי	נדחה
0 חזרות	נדחה
8.5 חזרות	נדחה
משקל 501	נדחה
אימון בלי סטים	נדחה
משך 0 או 481 דקות	נדחה
<code>havuraId</code> שאינו UUID	נדחה
חותמת זמן בלי <code>offset</code>	נדחית
201 סטים	נדחים
שגיאה מצביעה על השדה	ה-UI יכול לסמן אותו

5. בדיקות הרשאות – (22) `tests/rls.integration.test.ts`

כל בדיקה כאן כתובה כתקיפה. היא מנסה את מה שאסור, ועוברת רק כשהמסד מסרב.

5.1 אנונימי (4)

קריאה ל- `createine_ledger`, `workout_feed`, `workouts`, `exercises` – כולן חייבות להיכשל.

5.2 בידוד בין חבורות (10)

Mallory מול Alice, שתי חבורות נפרדות:

התקיפה	הצפי
קריאת האימונים של Alice	0 שורות
קריאת אימון לפי ה-id המדויק	0 שורות
קריאת הסטים דרך טבלת הבן	0 שורות
קריאת החבורה של Alice	0 שורות
מניית חבורות כדי למצוא קוד הזמנה	לא מופיעה
קריאת הפרופיל של Alice	0 שורות
קריאת ה-ledger של Alice	0 שורות
רישום אימון לחבורה זרה	NOT_A_MEMBER
מחיקת האימון של Alice	האימון שורד
Alice קוראת את שלה	שורה אחת – לוודא שלא חסמנו הכול

5.3 גבולות בתוך session מאומת (5)

התקיפה	הצפי	המנגנון
UPDATE workouts SET score = 100 על האימון שלי	הציון לא משתנה	GRANT ברמת עמודה
UPDATE profiles SET creatine_balance = 999999	היתרה לא משתנה	GRANT ברמת עמודה
קריאה ישירה ל-apply_creatine	שגיאה	EXECUTE נשלל
INSERT ישיר ל-workouts עם ציון 100	שגיאה	אין policy ל-INSERT
שינוי כותרת האימון שלי	מצליח	הגבול במקום הנכון

הבדיקה האחרונה קריטית: בלעדיה, "הכול חסום" היה עובר בהצלחה ונראה כמו אבטחה.

5.4 הצטרפות (3)

קוד שגוי → INVALID_INVITE_CODE ; קוד נכון פותח גישה **ורק אז**, עם בדיקת "לפני" ו-"אחרי" על אותו אימון; הצטרפות פעמיים אינה מזיקה.

5.5 הגעות – (11) tests/arrival.integration.test.ts

התקיפה / הבדיקה	הצפי
הכרזה והצגה כפעילה	שורה אחת פעילה
הכרזה חוזרת (הסלמה מ"בדרך" ל"במכון")	הגעה פתוחה אחת בלבד – האינדקס החלקי אוסף
החלון נבחר בשרת מהסטטוס	45 מול 150 דקות; לקוח לא יכול לבחור
הגעה שפגה מוסתרת לפי שעות המסד	אפס שורות
הגעה שפגה לפני שהוכרזה	נדחית ב- arrivals_window_forward
מי שמחוץ לחבורה רואה	אפס שורות
אנונימי רואה	שגיאה
הכרזה לחבורה זרה	NOT_A_MEMBER
רישום אימון סוגר ומקשר את ההגעה	workout_id ו- closed_at מלאים
ביטול ידני	אפס שורות פעילות
ביטול בשם מישוהו אחר	ההגעה שלו שורדת

6. בדיקות מסד נתונים – (13) tests/domain.integration.test.ts

6.1 זהות TypeScript ↔ SQL (7 מקרים)

סט בודד, אימון רגיל, אימון ארוך מאוד, אימון קצר מאוד, סט בעומס אפס, חזרות גבוהות, סינגלים כבדים.

לכל מקרה: רשמים אימון אמיתי, קוראים את הציון שהמסד חישב, ומשווים ל- `scoreWorkout()`. סובלנות 0.01 – PostgreSQL numeric מדויק ו-JavaScript הוא float64; להתעקש על זהות סיביות זו הונאה עצמית.

בלי הבדיקה הזו, עריכה של אחת הגרסאות ולא של השנייה עוברת בשקט, והמספר שהמתאמן רואה בזמן הזנה אינו המספר שהוא מקבל.

6.2 אינווריאנטים של ה-ledger (4)

- אותו `ref_id` שלוש פעמים → זיכוי אחד
- ירידה מתחת לאפס → `INSUFFICIENT_CREATINE`
- `creatine_balance == SUM(ledger.delta)`
- `balance_after` בכל שורה שווה לסכום המצטבר – ה-ledger משחזר את עצמו

6.3 חנות (2)

קנייה כפולה → `ALREADY_OWNED`; קנייה בלי כיסוי נכשלת ולא מעניקה כלום.

7. בדיקות (6) e2e/journey.spec.ts – UI

בדיקה	מה מכוסה
הגעה	מכון ריק → "אני במכון" → הצופה מופיע → רישום אימון סוגר את ההגעה אוטומטית
ביטול הגעה	"בדרך" → "סיימתי" → חוזר למצב ריק
המסע המלא	התחברות → onboarding → יצירת חבורה → קוד בן 6 תווים → אתגר ותחרות קיימים → חיפוש תרגיל → הזנת סט → ציון חזוי מופיע → שמירה → דף האימון → מופיע ב-feed → כפתור 150 מושבת ביתרה של 100
אימון ריק	אין כפתור שמירה כשאין סטים
קוד שגוי	הודעה ברורה
מבקר מנותק	הפניה ל- /login
דף נחיתה	נגיש בלי session
/api/health	ok , env.valid , db.reachable , rls.anonIsDenied

הבדיקה האחרונה היא בדיקת אבטחה שרצה על **הפריסה החיה**: אם מישוהו ירפה את ההרשאות בפרודקשן, חבילת ה-E2E נכשלת.

7.1 למה מסע אחד ארוך ולא שישה קצרים

הערך הוא בהוכחה שהמסע **השלם** מחזיק. פיצול היה מריץ setup יקר לכל בדיקה ומפסיק לבדוק את התפרים – שהם מה שנשבר בפועל.

7.2 חשבונות בבדיקות

המסע המרכזי **נרשם דרך הטופס האמיתי** – בדיוק המסלול של משתמש חדש. אימות אימייל מושבת בפרויקט, ולכן `signUp` מחזיר session מיד וההרשמה ממשיכה ישירות ל-onboarding.

בדיקות שזקוקות לחשבון שני, וההרשמה אינה מה שנבדק בהן, מקבלות חשבון דרך ה-API admin ומתחברות דרך ה-UI – מהיר יותר בכמה שניות ושומר את הבדיקה ממוקדת.

8. בדיקות ידניות מתועדות

מה שלא מכוסה אוטומטית, ולמה:

למה ידנית	שיטה	תרחיש
דורש מפתחות Stripe; דף התשלום מתארח אצל צד שלישי	כרטיס בדיקה 4242 4242 4242 4242 → אימות זיכוי חד-פעמי ב-ledger	רכישת חבילה ב-Stripe
	curl עם stripe-signature שגוי → נדרש 400	webhook עם חתימה שגויה
המאייל המובנה מוגבל ל-2 הודעות בשעה	הדלקת ההגדרה → הרשמה → מסך "בדוק את המייל"	הפעלת אימות אימייל מחדש
	Chrome Android ו-Safari iOS	תצוגה בנייד אמיתי

9. מה שנמצא בזכות הבדיקות

תשעה פגמים אמיתיים. חלקם מהרצת הבדיקות, חלקם מהסתכלות באפליקציה החיה, וחלקם – החשובים ביותר – מהרצת דמו בגודל מלא ולא מקריאת קוד.

#	הפגם	איך נמצא	למה הוא לא נראה קודם
1	<code>rpadd(name, 2, '')</code> קיצץ כל שם לשני תווים – 'Dana' נשמר כ-'Da'	הסתכלות ב-feed	<code>rpadd</code> גם מרפד וגם חותך. 'Da' הוא שם חוקי; נראה רק כשארבעה חשבונות הופיעו יחד
2	שבועות שאיש לא פתח בהם את האפליקציה מעולם לא נסגרו ולא שולמו	בדיקת ה-ledger אחרי seed	דורש היסטוריה של יותר משבוע
3	היתרה נקראה 0 כי <code>.single()</code> על <code>profiles</code> החזיר ארבע שורות	הסתכלות בחנות	ה-policy עשה את עבודתו; הקוד הניח שורה אחת
4	<code>weekRangeUtc()</code> חישב היסט אזור-זמן אפס	בדיקת יחידה	הפונקציה לא הייתה בשימוש
5	ה-views קיבלו הרשאה ל-anon	<code>npm run db:verify</code>	<code>REVOKE ALL ON ALL TABLES</code> חל רק על מה שקיים באותו רגע
6	מחיקת חשבון הייתה בלתי אפשרית לכל מי שיצר חבורה	הרצת הדמו	דורש למחוק משתמש שהוא גם יוצר חבורה – דבר שקורה רק בזרימה מלאה
7	ה-feed יכול היה לדלג על שורות בגבול עמוד	ניתוח ה-cursor תחת 174 אימונים	דורש שני אימונים באותה דקה בדיוק
8	ניקוי שדה התאריך ב-logger זרק חריגה	סקירת קוד	<code>new Date('').toISOString()</code> זורק <code>RangeError</code> ; רק בנתיב "המשתמש מחק את הערך"
9	יום-בשבוע חושב מ-parsing מחדש של <code>toLocaleString</code>	סקירת קוד	תלוי-locale; עובד בסביבת הפיתוח ונשבר במקומות אחרים

9.1 השלושה שמלמדים הכי הרבה

מחיקת חשבון (6). כל מפתח זר שמצביע על `profiles` הוגדר `ON DELETE CASCADE` – חוץ מאחד: `auth.users`, שנשאר בברירת המחדל `RESTRICT`. מכיוון ש-`profiles` נמחק בשרשור מ-`auth.users`,

מחיקת כל חבר שאי פעם יצר חבורה נכשלה עם Database error deleting user ו-500. החשבון לא היה ניתן למחיקה לעולם.

התיקון הנאיבי היה גרוע בהרבה מהבאג. CASCADE היה גורם לכך שמחיקת המייסד תמחק את החבורה, והשרשור של החבורה היה לוקח איתו את **האימונים של כל החברים** – אדם אחד סוגר חשבון ומוחק היסטוריית אימונים של תשעה אחרים. SET NULL הוא המודל הנכון: חבורה היא אוביייקט משותף ששורד את החשבון שפתח אותו, ו-havura_members כבר מחזיק את הבעלות שבאמת חשובה.

דילוג ב-(7) feed. ה-cursor היה performed_at בלבד. שני חברים שסיימו באותה דקה יוצרים אותה חותמת, ו-performed_at < last מדלג על כולם. תוקן ל-(performed_at, id). **קודם זה היה מתועד כמגבלה ידועה; עכשיו זה פשוט מתוקן.**

היתרה שנקראה 0 (3). ה-policy על profiles חושף בכוונה את חברי החבורה כדי שה-feed יוכל להציג שמות, ולכן select בלי סינון החזיר שורה **לכל חבר**, single(). נכשל, והיתרה נפלה בשקט ל-0 – והתבטא כ"כל פריט בחנות לא נגיש".

RLS מצמצם את מה שמותר לראות. הוא לא מחליט איזו שורה התכוונת אליה.

9.2 קוד מת שנמצא בסריקה

סריקת exports גילתה ש-leaveHavuraAction ו-deleteWorkoutAction מומשו, נבדקו ברמת ההרשאות – ולא היו מחוברים לשום מסך. שני המסמכים טענו שהזרימות האלה קיימות. הן חוברו ל-UI במקום להימחק, כי המסמך צדק והמימוש היה חסר.

10. QA בגודל מלא

מעבר לחבילות האוטומטיות, הורצה חבורת דמו בגודל אמיתי, שנבנתה כדי **להפעיל** את המכניקות ולא רק להציג אותן. scripts/seed-demo.mjs דטרמיניסטי (PRNG עם seed קבוע), כך שמספר שמצוטט כאן נשאר נכון בהרצה הבאה.

מה נבנה	כדי לבדוק מה
11 חברים, 6 שבועות, 174 אימונים, 1,571 סטים	היקף אמיתי
חבורה שנייה עם חפיפה של שני חברים	מחליף החבורות ובידוד בין tenants
Roni ו-Alon מתאמנים באופן זהה	תיקו – האם הנתחים מאוחדים ומחולקים
Gil לא מתאמן כלל	האם מי שלא השתתף מדורג אך לא מקבל
5 שבועות שהסתיימו	סגירה עצלה עם עבודה אמיתית

התוצאות:

שבועות נסגרו • כל אחד שילם 500 מתוך קופה של 500 בדיוק 5
 אותו דירוג ואותו תשלום בכל שבוע 635 ו-635 Roni ו-Alon
 מדורג ב-5 שבועות, שולם 0 Gil
 בכל 11 החשבונות ledger-סכום ה cache == ledger
 תגמולי אתגר אפס תשלומים כפולים
 עמודים, $8+14 \times 20 = 174$, אפס חפיפות, אפס דילוגים 9 feed
 חנות $2,150 \rightarrow 550 \rightarrow 400$, שער נכון על כל פריט
 ציוד ציוד תואר שני ביטל אוטומטית את הראשון
 מחיקה הסטים נמחקו בשרשור, אפס יתומים
 עזיבה חבר עוזב; בעלים חסום עם הסבר

זהו ההבדל בין "הפיצ'ר קיים" לבין "הפיצ'ר עובד על נתונים אמיתיים בהיקף אמיתי".

11. הרצה

```
npm test # 110 unit – מהיר, offline
npm run test:integration # 46 מול המסד האמיתי
npm run test:e2e # 8 מול הפריסה החיה
npm run db:verify # 14 אינווריאנטים של הסכמה
npm run test:all # הכול
```

db:verify אינה חבילת בדיקות אלא בודקת שהמסמכים אומרים אמת – 14 אינווריאנטים: RLS פעיל בכל טבלה, ל-anon אין הרשאות, אין UPDATE על score ועל creatine_balance, יש לכל היותר הגעה פתוחה אחת לחבר לחבורה, אין הגעה שפגה לפני שהוכרזה, וה-cache שווה ל-ledger. כל אחת מהן היא טענה שמופיעה במסמך האבטחה.